



*Asociación Profesional de Cuerpos Superiores
de Sistemas y Tecnologías de la Información
de las Administraciones Públicas.*

Temario para la preparación de la Oposición al Cuerpo Superior de
Sistemas y Tecnologías de la Información de la Administración del
Estado.

TEMAS ESPECÍFICOS – BLOQUE B
I. ORGANIZACIÓN Y GESTIÓN DE LOS SISTEMAS DE
INFORMACIÓN

**Tema 47. Seguridad de sistemas (1). Análisis y gestión de
riesgos. Herramientas.**

AUTOR: María Teresa Avelino Carmona.

REVISOR: Elisa Martín Ortega.

Creación: septiembre 2022

Actualización:

ÍNDICE

1	INTRODUCCIÓN	4
2	SEGURIDAD DE LA INFORMACIÓN Y DE LOS SISTEMAS	5
2.1	DIMENSIONES DE LA SEGURIDAD DE LA INFORMACIÓN	5
2.2	ROLES TÍPICOS RELACIONADOS CON LA CIBERSEGURIDAD	6
2.3	SEGURIDAD INTEGRAL	7
2.4	SISTEMAS DE GESTIÓN DE LA SEGURIDAD DE LA INFORMACIÓN	7
2.4.1	CONTROLES DE SEGURIDAD DE LA ISO 27002.....	8
2.4.2	EL ANÁLISIS DE RIESGOS EN EL ENS.....	9
3	ANÁLISIS Y GESTIÓN DE RIESGOS	11
3.1	VOCABULARIO Y CONCEPTOS BÁSICOS	11
3.1.1	AMENAZAS TÍPICAS	11
3.2	ANÁLISIS DE RIESGOS	12
3.2.1	ANÁLISIS DE RIESGOS TRADICIONAL BASADO EN ACTIVOS	12
3.2.2	ANÁLISIS DE RIESGOS MODERNOS BASADO EN ESCENARIOS.....	13
3.2.3	ANÁLISIS DE RIESGOS CUALITATIVO VERSUS CUANTITATIVO	13
3.2.4	TENDENCIAS A FUTURO: ANÁLISIS DE RIESGOS BASADOS EN ADVERSARIOS.....	14
3.2.5	MAPA DE CALOR/MAPA DE RIESGOS/MATRIZ DE RIESGOS	14
3.2.6	CISNES BLANCOS, CISNES GRISES, CISNES NEGROS Y TEORÍA DE JUEGOS APLICADA AL ANÁLISIS DE RIESGOS ADVERSARIOS	15
3.2.7	PRONOSTICANDO RIESGOS A FUTURO: LOS KRI	15
3.2.8	OTROS PROCESOS SIMILARES Y EMPARENTADOS CON EL ANÁLISIS DE RIESGOS	16
3.3	GESTIÓN DE RIESGOS.....	16
3.3.1	ESTRATEGIAS DE GESTIÓN DE RIESGOS	16
3.3.2	RIESGO RESIDUAL	17
3.3.3	SELECCIÓN DE LAS SALVAGUARDAS/CONTRAMEDIDAS.....	17
4	METODOLOGÍAS DE ANÁLISIS Y GESTIÓN DE RIESGOS	19
4.1	MAGERIT	19
4.1.1	ORGANIZACIÓN DE LA DOCUMENTACIÓN DE MAGERIT	19
4.1.2	IMPLEMENTACIÓN DE LA METODOLOGÍA.....	19
4.2	OTRAS METODOLOGÍAS	20
5	HERRAMIENTAS PARA LA GESTIÓN DE RIESGOS	22
5.1	SUITE DE HERRAMIENTAS EAR/PILAR.....	22
5.1.1	PILAR BASIC Y MPILAR	22
5.1.2	CONFIGURACIÓN DE LA HERRAMIENTA PILAR	22
5.1.3	OBTENCIÓN E INSTALACIÓN DE LAS HERRAMIENTAS PILAR	23
5.2	OTRAS HERRAMIENTAS PARA IMPLEMENTAR UN AR.....	23
5.3	GUÍAS CCN-CERT Y OTROS RECURSOS QUE APLICAN EN LA GESTIÓN DE RIESGOS	24

6	IMPLEMENTACIÓN PASO A PASO DE UN ANÁLISIS DE RIESGOS CON MAGERIT/PILAR	25
6.1	LEVANTAMIENTO DEL MAPA DE ACTIVOS Y SU VALORACIÓN	25
6.2	IDENTIFICACIÓN Y VALORACIÓN DE LAS AMENAZAS POR SU PROBABILIDAD	26
6.3	ANÁLISIS Y EVALUACIÓN DEL RIESGO.....	26
6.4	ESTADO DE LAS SALVAGUARDAS.....	27
6.5	SELECCIÓN DE LAS SALVAGUARDAS	27
7	RESUMEN ESQUEMÁTICO	29
8	GLOSARIO	31
9	TEST	34
9.1	PREGUNTAS DE TEST	34
9.2	SOLUCIONES A LAS PREGUNTAS DE TEST	36
10	BIBLIOGRAFÍA BÁSICA.....	37
10.1	BIBLIOGRAFÍA BÁSICA	37
10.2	BIBLIOGRAFÍA PARA AMPLIAR EL TEMA.....	37

1 Introducción

En la era del “oro azul” del Big Data, el dato, y sobre todo el dato convertido en información y conocimiento, se convierte en el activo más crítico para las organizaciones.

Es por ello por lo que es crucial conocer el riesgo al que están sometidos los activos de la organización que participan de manera directa o indirecta en el ciclo de vida del dato/información/conocimiento. Y es preciso tener en cuenta que no estamos hablando solamente de silos de datos, sino también de las personas que tratan o administran las bases de datos, los programas que manipulan la información, las comunicaciones a través de las que se transmite, los sistemas donde se alberga y hasta los lugares donde reposa. Cualquier amenaza que se materialice en cualquier de ellos (alguien que exfiltre información a terceros para lucrarse, o bien con el objetivo de realizar un chantaje, un troyano en una aplicación, la corrupción de una base de datos, una caída de la red, un incendio en el CPD, etc.) pueden suponer cuantiosas pérdidas tanto económicas como reputacionales de difícil o imposible reparación a veces.

Con un escenario en el que las vulnerabilidades de tipo “0-day” (desconocidas hasta para los creadores del software), son cada vez más frecuentes, el conocimiento del riesgo no puede ser algo estático y que se aborde de forma esporádica, sino que debe ser recalculado y gestionado de manera continua, de modo que se puedan tomar decisiones basadas en el conocimiento de primera mano y en tiempo real de los escenarios de riesgo y potenciales impactos.

En cuanto a la aplicación del análisis de riesgos, éste debe ser siempre el punto de partida para implantar un Plan Director de Seguridad de la Información, o bien como sería más preferible, implantar un Sistema de Gestión de la Seguridad de la Información (SGSI) usando cualquier marco aplicable, tal como el Esquema Nacional de Seguridad en la Administración, o bien la Norma ISO 27001, o el marco COBIT propuesto por ISACA.

En todos los marcos de gobierno de la seguridad de la información, se parte de un análisis de riesgos, para conocer el nivel de exposición de los activos de información y poder aplicarle posteriormente las medidas (salvaguardas) adecuadas.

Pero no sólo el Análisis de Riesgos aplica en los SGSI, sino que en un sentido más amplio, y si abarcamos otras cuestiones y no sólo los activos de información, puede ser el punto de partida de un Sistema de Gestión de la Continuidad de Negocio (SGCN) si partimos de un Análisis de Impacto (BIA) que se centra más que en el riesgo en sí, en el impacto que supone el riesgo en cuestión. No obstante todo lo relativo a SGCN se verá en el tema 127 con más detalle.

Por otra parte, y también en el marco de la protección de datos de carácter personal, es preciso calcular el riesgo que para los derechos y libertades de los ciudadanos supone el tratamiento de sus datos, sobre todo si los datos son especialmente sensibles, o bien los tratamientos suponen una gran amenaza para la privacidad. El tema 27 y sobre todo el 82 se extenderán sobre la adecuación de protección de datos de carácter personal y las medidas a abordar.

2 Seguridad de la información y de los sistemas

Actualmente, se habla a todas horas del concepto “Ciberseguridad”. Se podría decir que todo lo “ciber” está de moda y en todas las actividades organizativas implicando vocablos y novedades tales como: Ciberseguros, ciberataques, ciberespacio, ciberdelito, ciberdefensa, ciberinteligencia...

Como acabamos de introducir, la información es el activo más valioso que poseen las organizaciones y su seguridad, por tanto, es una actividad primordial para protegerla. Si bien a menudo se confunde la seguridad de la información con la seguridad de los sistemas TI y además con el más moderno término de ciberseguridad usando indistintamente cualquiera de los mismos, dichos términos no son del todo equivalentes.

Mientras que la definición de Seguridad de la Información según la Norma ISO 27001 es:

“La preservación de la confidencialidad, la integridad y la disponibilidad de la información. Puede, además, abarcar otras propiedades, como la autenticidad, responsabilidad, fiabilidad y prevención del repudio”, la definición de seguridad de los sistemas de tecnologías de la información y comunicaciones es:

La protección de la información almacenada, procesada o transmitida, por Sistemas de las Tecnologías de la Información y las Comunicaciones (Sistemas), mediante la aplicación de las medidas necesarias que aseguren o garanticen la confidencialidad, integridad y disponibilidad de la información y la integridad y disponibilidad de los propios Sistemas.

La diferencia es sutil, pero comporta que: La Seguridad de la Información comprende no sólo la seguridad de los sistemas TI donde se alberga o las redes donde transita, **sino de todas sus formas de expresión, almacenamiento y comunicación, incluyendo soportes analógicos tradicionales tales como el papel o incluso la comunicación oral de la misma.**

Por otra parte, el concepto de *Ciberseguridad* se verá ampliamente en el siguiente tema (48), pero como pincelada indicar que hace referencia **al conjunto de actividades dirigidas a proteger el ciberespacio contra el uso indebido del mismo, defendiendo su infraestructura tecnológica, los servicios que prestan y la información que manejan.** El ciberespacio debe entenderse por el conjunto de dominios, redes y sistemas que pueblan Internet y resto de redes, estén interconectadas o no a Internet.

2.1 Dimensiones de la seguridad de la información

El Esquema Nacional de Seguridad establece cinco dimensiones para la seguridad de la información. Estas dimensiones son:

- **Autenticidad:** Propiedad consistente en que una entidad es lo que dice ser. Si se produce un fallo en el mecanismo de autenticación para verificar la autenticidad de una entidad en un sistema, podemos sufrir una suplantación de identidad digital, perjudicando tanto al sujeto suplantado como al resto de usuarios del sistema, ya que confiarán en un impostor.
- **Confidencialidad:** Propiedad de la información que impide que ésta esté disponible o sea revelada a individuos, entidades o procesos no autorizados. No hay que confundir confidencialidad con privacidad, ya que esta última se refiere a los datos personales en particular, y la confidencialidad es un concepto más general.
- **Disponibilidad:** Propiedad de ser accesible y utilizable a petición por una entidad autorizada. A menudo se olvida que la disponibilidad es también una dimensión de seguridad, ya que se suele considerar algo relativo a la operativa de sistemas (sistema caído, sistema degradado).
- **Integridad:** Propiedad o característica consistente en que el activo no ha sido alterado de manera no autorizada. Hay que indicar que la alteración puede ser accidental (corrupción de una base de datos, por ejemplo) o intencionada (un *ransomware*, por ejemplo).
- **Trazabilidad:** *Cualidad que permite que todas las acciones realizadas sobre un sistema de tecnología de la información sean asociadas de modo inequívoco a un individuo o entidad.*

Aparte de estas dimensiones, se pueden considerar algunas más:

- **No repudio (o irrenunciabilidad):** Este concepto está ligado típicamente a la firma electrónica y consiste en la capacidad de un sistema o entidad para evitar que otra niegue una acción o el

envío de un mensaje o la autoría de un documento. Típicamente, como decimos, está ligado a la firma electrónica.

- **Privacidad:** Derecho de los individuos a controlar qué datos relativos a ellos pueden ser recopilados y almacenados y quién y para qué puede tener acceso a ellos.
- **Conservación o Persistencia:** Antes de la llegada del ENS, existían los “Criterios ACIDA” en la guía de Seguridad, Normalización y Conservación del año 2004. Todavía en el EJIS se mantiene la dimensión de conservación a tener en cuenta. A caballo entre la interoperabilidad y la seguridad, la persistencia de los documentos y datos a través de mecanismos que garanticen la perdurabilidad necesaria se puede considerar también relevante desde el punto de vista de la seguridad.

2.2 Roles típicos relacionados con la ciberseguridad

Relacionados con el concepto de ciberseguridad, seguridad de la información, seguridad de las instalaciones y seguridad de los sistemas TIC, a nivel de las organizaciones podemos encontrar diversos roles. Enunciaremos algunos de los más típicos:

- **CSO** (Chief Security Officer), equivalente en español Director de Seguridad, se encarga de lo que se denomina seguridad corporativa. Debe tener la visión total del negocio, comprender los riesgos a los que debe enfrentarse la organización y cómo tratarlos; establecer planes de continuidad y recuperación ante desastres y formar parte del Comité de Crisis. En España sus funciones están reguladas por la Ley de Seguridad Privada Ley 5/2014, de 4 de abril. En particular y en lo que nos ocupa en este tema, una función de suma importancia que ostenta es la de interlocución y enlace con la Administración, especialmente con las Fuerzas y Cuerpos de Seguridad, respecto de la función de seguridad integral de la entidad, empresa o grupo empresarial que les tenga contratados, en relación con el cumplimiento normativo sobre gestión de todo tipo de riesgos.
- **CISO** (Chief Information Security Officer), equivalente en español de Responsable de Seguridad de la Información se ocupa de la Política de Seguridad de la Información (PSI), así como de aconsejar las medidas que se deben adoptar para implementar esta PSI. De este modo, es el responsable de la estrategia de ciberseguridad (o más ampliamente de seguridad de la información corporativa) desde la fase de planificación, pasando por su desarrollo, ejecución y el control. Es un cargo directivo (o debiera serlo), y es responsable de los perfiles técnicos. Además, ha de reportar a otros directores (CTO, CDO, CIO...) o al departamento afectado, todas las acciones y logros en ciberseguridad. A veces, ha de reportar directamente al CEO. Se trata de un cargo que combina el mundo técnico y el de negocio, y debe tener grandes dotes de traducción entre ambos mundos.
- **RSI:** Responsable de Seguridad de la Información: El RD 43/2021 (se verá en el siguiente tema), determina la obligatoriedad de esta figura para los sujetos obligados por la directiva NIS (operadores de servicios de telecomunicaciones y prestadores de servicios de confianza), similar al CISO, que tiene unas claras funciones atribuidas. Destacaremos por lo que nos ocupa en este tema entre otras, la de **supervisar y desarrollar la aplicación de las políticas de seguridad, normativas y procedimientos derivados de la organización, supervisar su efectividad y llevar a cabo controles periódicos de seguridad.**

Además de los roles directivos, existen otros roles técnicos, enumeraremos algunos de los más relevantes:

- **Arquitecto de ciberseguridad:** Analiza las arquitecturas de sistemas e incorpora las medidas técnicas y controles de seguridad precisos. Traduce medidas de seguridad de alto nivel indicadas por el RSI en medidas técnicas más tangibles. Por ejemplo, si por parte del RSI se determina que un sistema debe contar con un mecanismo de autenticación robusto debido a que se ha categorizado como de nivel medio o alto en la dimensión de autenticidad, el arquitecto de ciberseguridad ingeniará un mecanismo de doble factor robusto como puede ser el uso de contraseña y un certificado digital en tarjeta criptográfica. También y como segunda responsabilidad, analiza el mercado de soluciones de ciberseguridad y propone las que considera se adaptan mejor a las necesidades de la organización.

- **Auditor ciber (o auditor de seguridad de la información):** Audita los sistemas frente al marco de gobierno de la ciberseguridad, estándares, normas o políticas de aplicación y determina el grado de cumplimiento de los mismos. Además, analiza el riesgo que dichos sistemas presentan e informa al RSI y a la alta dirección de dichos riesgos fundamentados en el análisis efectuado.
- **Auditor técnico ciber, hacker ético, pentester:** Analiza los sistemas en la búsqueda de vulnerabilidades que puedan propiciar incidentes de seguridad. Por ejemplo, determina si en una aplicación expuesta en Internet le falta de un mecanismo de control de sesiones que puede provocar un ataque conocido como “suplantación por secuestro de sesión”.
- **Administrador de ciberseguridad:** Aplica las medidas que el RSI o el arquitecto de ciberseguridad han determinado, monitoriza los sistemas y resuelve pequeños incidentes de seguridad.
- **Analista forense:** Investiga en profundidad, de forma meticulosa y objetiva los incidentes de seguridad ocurridos en una organización, a fin de determinar las causas y explicar con el mayor detalle posible cómo han ocurrido.

2.3 Seguridad integral

Tradicionalmente, se ha distinguido siempre la seguridad de las TIC de la seguridad de las instalaciones o de los procesos de producción u operaciones del negocio. Este enfoque antiguo circunscribía las tareas de seguridad de la información típicamente a la protección de los activos TIC frente a las amenazas típicas lógicas tales como fallos en el software o vulnerabilidades que propiciasen ataques o bien frente a virus, troyanos y otros ataques similares.

A partir del 2004 y más recientemente con toda la legislación de protección de infraestructuras críticas, estratégicas, operadores y similares, se considera la seguridad de forma integral. Esto es: La protección de los activos críticos de negocio desde todos los prismas.

Por otra parte, la convergencia de los mundos OT (industrial y operacional) y TI hace cada vez más difusa la diferencia ente la protección de los procesos industriales y la protección de los activos de información. Si se añade además el problema de la subida a Internet de controles y procesos con lo que se denomina Internet de las cosas (IoT en inglés), se puede concluir en que muy probablemente y a medio plazo vayamos hacia una **regulación única de seguridad integral** que aúne la necesidad de mejorar la ciberseguridad pero cada vez abarcando más y más sectores de aplicación, resultado de la convergencia de todas las directivas que se están preparando actualmente (NIS2, DORA, etc.).

Esta convergencia hace que los roles del CISO y del CSO sean cada vez más interdependientes.

2.4 Sistemas de Gestión de la Seguridad de la Información

Un Sistema de Gestión de la Seguridad de la Información implementa procesos y controles de seguridad de la información de forma continua en un ciclo de Deming (Plan-Do-Check-Act), esto es, Planificar, Ejecutar, Evaluar el resultado y Actuar de nuevo para mejorar el resultado.

Se puede decir que la implantación de un SGSI puede ser primero un proyecto (Implantación de un Plan Director de Seguridad de la Información) pero después debe convertirse en un servicio horizontal a toda la organización, de modo que se cuente con una mejora continua en la seguridad de la información.

El estándar más conocido para la seguridad de la información es la ISO 27001:2017. El ENS se puede considerar también un estándar que implemente un SGSI si bien como se verá en el siguiente tema existen ciertas diferencias.

Algunos marcos de gobierno que incluyen la seguridad entre sus procesos de control serían **COBIT** (la versión actual es la del 2019) o **NIST** (Cybersecurity Framework).

Hay que puntualizar que COBIT se enfoca principalmente en el valor que aporta TI al negocio de modo que la seguridad es un proceso que debe aportar valor al mismo.

Si bien existen diversos estándares para implementar SGSIs, es común a todos ellos **abordar los siguientes pasos ordenados:**

1. Definir los objetivos, misión, y contar con una Política de Seguridad de la Información (PSI) con roles y responsabilidades.
2. Evaluar los riesgos de seguridad de la información.

3. Analizar dichos riesgos y plantear un plan de tratamiento de los mismos.
4. Documentar todo el plan que se quiere abordar desarrollando además la PSI con normas, procedimientos e instrucciones técnicas.
5. Implementar el plan de tratamiento de los riesgos mediante medidas técnicas, organizativas, procedimentales, controles y formación.
6. Auditoría de seguridad TI y del plan implementado junto con la documentación (auditoría del SGSI).
7. Certificación del SGSI.

2.4.1 Controles de seguridad de la ISO 27002

La norma ISO27001 para la implantación de un SGSI cuenta con la norma ISO 27002 para determinar los controles de seguridad que se deben establecer en los sistemas de información de una organización.

Los controles típicamente se dividen en dominios. Recientemente en 2022 la norma ISO 27002 ha cambiado respecto a la anterior del 2017 y ahora en vez de contar con 14 dominios de seguridad ha pasado a cuatro dominios o grupos principales y los controles quedan así:

- 37 controles de seguridad de tipo organizativo.
- 8 controles relativos a la seguridad del personal.
- 14 controles relativos a la seguridad física.
- 34 controles de carácter técnico.

Es interesante hacer nota que existe un paralelismo (algunas semejantes y relaciones) entre los controles de la ISO 27002 y los del ENS.

Los **controles de tipo organizativo** van dirigidos a la organización de la seguridad de la información (roles, responsabilidades, estructura de gobierno, comités, documentación, procedimientos). Típicamente la documentación de seguridad sigue una jerarquía normativa con la Política de la Seguridad de la Información en la cúspide de la pirámide. En la PSI se marca el contexto normativo de referencia (qué legislación es de aplicación, qué marco o estándar se va a seguir, cuál es la estructura de comités y roles de seguridad, qué principios y objetivos de alto nivel se persiguen).

Las normas o directrices son la documentación de segundo nivel que detalle los objetivos de seguridad de la organización. Detallan qué queremos hacer, como por ejemplo, controlar el acceso a los sistemas de información.

Los procedimientos e instrucciones de seguridad indican cómo se van a implementar los objetivos expuestos en las normas. Por ejemplo, implementaremos un control de acceso mediante un mecanismo de usuario y contraseña con una determinada longitud, una caducidad a los 30 días y una complejidad determinada.

Los controles relativos a la seguridad del personal inciden en la responsabilidad del personal en la seguridad de la información. Según Bruce Schneier, criptógrafo y gran maestro en la ciberseguridad, *el factor humano es el eslabón más débil en la cadena*.

Por ejemplo, los usuarios no deben revelar las contraseñas, deben guardar bajo llave los documentos sensibles, no deben mantener conversaciones sobre información sensible fuera del trabajo, no deben copiar información digital en medios analógicos como papel, etc.

Además, se indica cómo se va a concienciar y formar al personal y la difusión de los deberes y obligaciones de todos los usuarios. Además, se deberá indicar qué controles se van a aplicar a personal externo colaborador o proveedor.

Los **controles relativos a la seguridad física** inciden en el control físico del acceso a las zonas donde se procesa la información (típicamente los CPD o las oficinas donde trabajan el personal IT) o se gestionan los activos involucrados en la misma tales como redes de comunicaciones o elementos esenciales para los centros de procesamiento tales como generadores eléctricos, centros de baja o media tensión, aire acondicionado, etc.

Los **controles de carácter técnico** típicos son los de control acceso a los sistemas, copias de seguridad y respaldo, desarrollo seguro, aplicación de cifrado a las comunicaciones entre clientes y servidores, etc.

2.4.2 El Análisis de Riesgos en el ENS

El RD. 311/2022 por el que se actualiza el Esquema Nacional de Seguridad, comienza ya haciendo hincapié en el incremento de los riesgos pues en su introducción nos dice textualmente: *“...considerando que la transformación digital ha supuesto un incremento de los riesgos asociados a los sistemas de información que sustentan los servicios públicos y que el sector privado se encuentra igualmente inmerso en la transformación digital de sus procesos de negocio, ambos tipos de sistemas de información se encuentran expuestos al mismo tipo de amenazas y riesgos.”*

Entre los principios básicos que deben regir el ENS, el artículo 7 del ENS nos habla claramente de la **gestión de la seguridad basada en los riesgos (se subraya los más relevantes):**

Artículo 7. Gestión de la seguridad basada en los riesgos.

1. *El análisis y la gestión de los riesgos es parte esencial del proceso de seguridad, debiendo constituir una actividad continua y permanentemente actualizada.*

2. *La gestión de los riesgos permitirá el mantenimiento de un entorno controlado, minimizando los riesgos a niveles aceptables. La reducción a estos niveles se realizará mediante una apropiada aplicación de medidas de seguridad, de manera equilibrada y proporcionada a la naturaleza de la información tratada, de los servicios a prestar y de los riesgos a los que estén expuestos.*

Así pues se nos indica que al análisis de riesgos debe ser una actividad que se realice de manera continua, y que es preciso gestionar los riesgos para reducirlos a los niveles aceptables (lo que hemos definido como “umbral de aceptación de riesgos o apetito por el riesgo”).

En la definición de cómo se tienen que implementar esos principios básicos, el artículo 14 trata del Análisis de Riesgos:

Artículo 14. Análisis y gestión de los riesgos.

1. *Cada organización que desarrolle e implante sistemas para el tratamiento de la información o la prestación de servicios realizará su propia gestión de riesgos.*

2. *Esta gestión se realizará por medio del análisis y tratamiento de los riesgos a los que está expuesto el sistema. Sin perjuicio de lo dispuesto en el anexo II, se empleará alguna metodología reconocida internacionalmente.*

3. *Las medidas adoptadas para mitigar o suprimir los riesgos deberán estar justificadas y, en todo caso, existirá una proporcionalidad entre ellas y los riesgos.*

Como se puede apreciar, **se indica la obligatoriedad del Análisis y tratamiento de los riesgos, del uso de metodologías reconocidas y de la justificación de las medidas seleccionadas para mitigar los riesgos.**

En cuanto los controles concretos y como implantarlos, en el Marco Operacional, el control **op.pl.1** (Análisis de Riesgos), aplica a todas las categorías.

Para nivel MEDIO se debe aplicar el refuerzo R1y para el nivel alto el refuerzo R2.

El Refuerzo R1 consiste en un Análisis de riesgos semiformal: Usando un lenguaje específico, con un catálogo básico de amenazas y una semántica definida. Es decir, una presentación con tablas que:

- [op.pl.1.r1.1] Valore cualitativamente los activos más valiosos del sistema.
- [op.pl.1.r1.2] Cuantifique las amenazas más probables.
- [op.pl.1.r1.3] Valore las salvaguardas que protegen de dichas amenazas.
- [op.pl.1.r1.4] Valore el riesgo residual.

El Refuerzo R2 consiste en un Análisis de riesgos formal: Usando un lenguaje específico, **con un fundamento matemático reconocido internacionalmente**. Los controles a aplicar son similares al refuerzo R1 solo que, como se indica, la metodología debe ser rigurosa en cuanto al cálculo del riesgo.

- [op.pl.1.r2.1] Valore cualitativamente los activos más valiosos del sistema.
- [op.pl.1.r2.2] Cuantifique las amenazas posibles.
- [op.pl.1.r2.3] Valore y priorice las salvaguardas adecuadas.
- [op.pl.1.r2.4] Valore y asuma formalmente el riesgo residual.

3 Análisis y gestión de riesgos

Para poder implantar un SGSI, acabamos de ver que es vital analizar los riesgos de TI y planificar posteriormente un plan para gestionar dichos riesgos.

3.1 Vocabulario y conceptos básicos

Antes de entrar en materia vamos a definir algunos conceptos que usaremos a lo largo del resto del tema:

- **Activo de información:** Proceso de negocio, servicio, soporte, base de datos, sistema, redes, personas y elementos que intervienen en el procesamiento de la información.
- **Dominio:** Contexto de seguridad con políticas diferenciadas de otros. Por ejemplo, una sede en un país está sometida a diferentes regulaciones. Pero también en una misma organización podemos contar con un dominio de seguridad para aplicaciones de uso público con políticas de acceso más relajadas y otro dominio para información de uso interno, confidencial (para nuestra organización), restringidas sólo a determinados usuarios, etc. Cada dominio típicamente contará con sus propios activos.
- **Escenario de riesgo:** Situaciones en las que se producen los riesgos de ataque a la información. Por ejemplo: Si dejamos abierta la puerta de la oficina al irnos, si dejamos un dossier con información sin guardar bajo llave, si usamos una contraseña fácil de predecir en un PC con acceso a información sensible, si no hacemos una copia adecuada de un fichero de información, etc.
- **Amenaza:** Eventos que pueden desencadenar un incidente en la Organización, produciendo daños materiales o pérdidas inmateriales en sus activos.
- **Vulnerabilidad:** Error o debilidad que, de llegar a explotarse, puede ocasionar una exposición a riesgos del sistema, intencionalmente o no.
- **Salvaguarda o contramedida:** Procedimiento o mecanismo tecnológico que reduce el riesgo. Puede tratarse de medidas de previsión o de preparación, de disuasión, protección, detección, aislamiento, de "lucha", de recuperación, restauración o compensación.
- **Impacto:** Consecuencia que sobre un activo tiene la materialización de una amenaza. Más generalmente, la medida del efecto de un Incidente, problema o cambio en los procesos de negocio.
- **Riesgo:** Estimación del grado de exposición a que una amenaza se materialice sobre uno o más activos causando daños o perjuicios a la Organización.

3.1.1 Amenazas típicas

A continuación, se proponen una serie de amenazas típicas que las organizaciones deben tener siempre en cuenta en su análisis de riesgos.

Amenazas contra la confidencialidad de la información:

- **Fugas de información:** De forma no intencionada, la información acaba en manos de quién no debe poseerla. Las causas típicas suelen ser: Error humano, falta de formación en aplicaciones que manipulan la información o bien errores en la aplicación siendo uno muy típico es la falta de perfilado adecuado de la misma. También puede ocurrir por error en la configuración del propio sistema.
- **Revelación intencionada de información:** Un usuario interno de la organización por diversas motivaciones (venganza, convicciones morales, políticas, etc.) decide revelar información de la que tiene acceso.
- **Ingeniería social:** Un atacante utiliza tretas para sonsacar información de los usuarios que tienen acceso a la misma. Un ejemplo sería alguien que se hace pasar por técnico de microinformática y le pide por teléfono a un usuario que le proporcione su contraseña para configurar una nueva aplicación.
- **Exfiltración de información:** Un atacante utiliza vulnerabilidades en las aplicaciones que tratan la información para extraer dicha información fuera de la organización. Un ejemplo sería un ataque de SQL Injection contra un servidor de aplicaciones con acceso desde Internet.

Amenazas que afectan a la integridad/disponibilidad de la información:

- **Fallos graves en el sistema que aloja la información:** El sistema que trata o aloja la información sufre un fallo grave que causa la indisponibilidad temporal o total de la información. Un ejemplo sería la rotura de varios discos a la vez en un sistema configurado en RAID-5 que no tiene redundado en otra ubicación.
- **Caída/Corrupción del Sistema Gestor de la Base de Datos:** La base de datos sufre una indisponibilidad grave o bien se corrompe el sistema de ficheros que la alberga.
- **Caída o destrucción total o parcial de la aplicación que maneja los datos:** El sistema y la base de datos está bien, pero la aplicación que maneja la información está caída, deteriorada o destruida.
- **'Ransomware' o criptoataque:** Un malware ataca nuestro sistema cifrando los archivos de modo que están irrecuperables salvo que se halle la clave para su descifrado. El atacante típicamente pide rescate para proporcionar esta clave.
- **Ataques externos por Denegación de Servicio:** Los sistemas y bases de datos están bien pero los usuarios no pueden acceder a la información porque está siendo objeto de un ataque y no se puede llegar a la misma.
- **Caída de las comunicaciones entre los datos y los usuarios:** Similar a lo anterior pero esta vez no hay un ataque sino un fallo en las comunicaciones entre usuario y sistemas.

Amenazas que afectan a la trazabilidad:

- **Borrado o alteración de logs de auditoría de las aplicaciones, de la base de datos o del sistema:** Para encubrir acciones indebidas sobre el sistema y no poder localizar al causante de las mismas.

3.2 Análisis de Riesgos

Se puede definir el Análisis de Riesgos para la Seguridad de la Información como el procedimiento sistemático por el cual se puede medir de forma cualitativa o cuantitativa de forma sopesada la probabilidad de que una amenaza se materialice sobre un activo de información ocasionando un daño severo en el mismo por el impacto que la amenaza materializada (incidente o ataque) ha ocasionado.

Por ejemplo, si tenemos un servidor de base datos con una base de clientes, y el servidor está valorado en 30 mil euros, y la base de datos de clientes en 100 mil euros, y un *ransomware* cuya probabilidad estimamos en un 1% de ocurrencia, el riesgo sería:

$$R = (1/100) * 130.000 = 1.300 \text{ euros.}$$

Como veremos después, una medida posible sería cubrimos con un seguro que cubriese al menos esa cantidad.

Pero desde un punto de vista cualitativo, la pérdida de reputación por haber perdido la base de datos de clientes puede suponer que la empresa pierda totalmente su negocio y el valor entonces sería incalculable, de ahí que no todos los riesgos se pueden estimar en base a valores económicos.

En la actualidad existen dos corrientes metodológicas para abordar un análisis de riesgos. Una es la tradicional basada en la valoración de activos de información. La otra más flexible y que se está imponiendo cada vez es el análisis de riesgo basado en escenarios. A continuación, veremos cómo operan cada una de ellas.

3.2.1 Análisis de riesgos tradicional basado en activos

Este análisis se basa en determinar las amenazas sobre activos de información así como el impacto de la materialización de la amenaza sobre los mismos. Por ejemplo, si consideramos un activo de información el servicio de tramitación de expedientes, una amenaza sería por ejemplo, que se saturase el servicio por falta de recursos (agotamiento de recursos para proporcionar el servicio) y el impacto sería el número de ciudadanos que no podrían realizar sus trámites porque no existen más manejadores de sesión para darles paso al servicio. Aquí habría que ver qué problema pueden tener esos ciudadanos que se han quedado sin poder realizar su trámite ya que no es lo mismo un trámite para solicitar cita previa para gestionar una beca que para solicitar una prueba médica importante para la salud.

La metodología MAGERIT se basa en este enfoque.

3.2.2 Análisis de riesgos modernos basado en escenarios

El análisis de escenarios se basa en plantear y analizar distintas situaciones considerando los riesgos que estas pueden representar para la organización, sin limitarse al impacto o daño concreto en los activos.

Por ejemplo, supongamos que valoramos situaciones que pueden paralizar una organización y contemplamos el escenario de ataque por *ransomware*. Independientemente de dónde se origine o a qué activo dañe más, un ataque por *ransomware* es una situación de alto impacto para una organización con una probabilidad dependiente del grado de amenaza global, exposición, modernización de equipos, gestión proactiva, etc.

Un escenario de riesgo que provocaría un ataque de este tipo sería, por ejemplo, no contar con un antivirus/antimalware actualizado y potente y permitir además la descarga indiscriminada de archivos de Internet sumado a una mala concienciación de los usuarios sobre los peligros del *phishing* y campañas más habituales y rematado además por un mal gestor *antiphishing* en el correo corporativo. Este escenario propiciaría enormemente un ataque de estas características. Cualquier medida que cortase cualquiera de los elementos de esta cadena reduciría el riesgo de este tipo de ataque.

3.2.3 Análisis de riesgos cualitativo versus cuantitativo

En el análisis de riesgos cualitativo no se busca cuantificar las consecuencias de los riesgos en dinero o coste, sino ordenar su importancia, dándole un valor simbólico asociado a su magnitud. Igualmente, cuando se estima la probabilidad de las amenazas, en el análisis cuantitativo se indica un valor porcentual concreto (por ejemplo, un 15% de probabilidad) mientras que en el análisis cualitativo se da una idea aproximada de la probabilidad (Muy Alta, Alta, Media, Baja).

La siguiente figura muestra la graduación cualitativa del riesgo según la metodología MAGERIT.

valor		criterio
10	extremo	daño extremadamente grave
9	muy alto	daño muy grave
6-8	alto	daño grave
3-5	medio	daño importante
1-2	bajo	daño menor
0	despreciable	irrelevante a efectos prácticos

Figura 1: Escala de gradación de riesgos según MAGERIT

La recomendación que proporciona MAGERIT sobre cómo abordar un Análisis de Riesgos cualitativo o cuantitativo:

- **Homogeneidad:** Es importante poder comparar valores aunque sean de diferentes dimensiones, así como poder determinar si es más grave el daño en una dimensión o en otra.
- **Relatividad:** Es importante poder relativizar el valor de un activo en comparación con otros activos.

La ventaja de un análisis cuantitativo es que se pueden abordar estudios económicos comparando lo que se arriesga con lo que cuesta la solución respondiendo a cuestiones importantes tales como si merece la pena invertir determinado dinero en ciertas salvaguardas o más genéricamente, **qué salvaguardas optimizan el dinero invertido en ellas** (mayor relación coste/beneficio). Por otra parte se puede presentar a la dirección proyectos con elementos importantes tales como cuál es el ROI (Retorno de la Inversión) o cuánto es razonable que cueste la prima de un seguro si elegimos la opción de transferir el riesgo a una entidad aseguradora.

El uso de escalas cualitativas permite abordar un análisis de riesgos más rápido, ya que posicionan el valor de cada activo en un orden relativo respecto de los demás.

La limitación de las valoraciones cualitativas es que no permiten comparar valores más allá de su orden relativo. No se pueden sumar valores y, por tanto, es más difícil obtener valores acumulados.

En cuanto a si es mejor o peor abordar un análisis cuantitativo frente a uno cualitativo, **el análisis cuantitativo deja fuera los criterios intangibles del análisis de riesgos**, pues si bien es posible ponerle precio a casi todo, al entrar en valoraciones más abstractas (intangibles como la credibilidad de la organización o las vidas humanas) la valoración económica exacta puede ser escurridiza y motivo de disputas e incluso de disparidad de convicciones morales.

3.2.4 Tendencias a futuro: Análisis de riesgos basados en adversarios

En el mundo de la ciberseguridad con un número creciente de ataques intencionados, guerra híbrida y confrontación en el ciberespacio se ha propuesto recientemente este modelo de Análisis de Riesgos para tratar amenazas que se originan a partir de acciones intencionadas de adversarios.

Este enfoque nace de la Teoría de Juegos (una rama de las matemáticas que trata de las dinámicas en las que participan dos o más individuos).

En este modelo, la gestión de riesgos no se considera desde un único prisma (el de la organización que hace frente a amenazas exteriores con solo tomar medidas y esperar que surtan efecto), sino que **se modeliza como un juego competitivo en el que varios jugadores compiten por una serie de recursos** (controlar un sistema de información) y las decisiones que uno toma son respondidas por el adversario y así sucesivamente. De este modo, además de modelizar el mapa de activos y riesgos para el defensor, éste debe adivinar el mapa de activos y riesgos (oportunidades) y debilidades del atacante.

Es preciso mencionar que la herramienta PILAR cuenta con un apartado en el Análisis de Riesgos denominado *“Perfil del Atacante”* que tiene en cierto modo en cuenta esta casuística, si bien no se modeliza mediante teoría de juegos tal y como se propone en esta teoría más moderna de adversarios.

3.2.5 Mapa de calor/Mapa de Riesgos/Matriz de Riesgos

El mapa de riesgos, el mapa de calor y la matriz de riesgos son herramientas útiles en la gestión de riesgos ya que se obtiene mucha información para toma de decisiones, resumida y además muy visual.

Un mapa de riesgos es una tabla en la que, por columnas se colocan los posibles eventos que pueden provocar los riesgos (amenazas). En las siguientes columnas, se colocarán las probabilidades/frecuencias, el impacto y otras consideraciones o factores que puedan explicar dichos riesgos.

Por otra parte, **la matriz de riesgos** consiste en ubicar cada riesgo en función del impacto y probabilidad en un cuadrante para facilitar su visualización. El cuadrante tiene dos ejes, por un lado, la probabilidad/frecuencia y por otro lado, el impacto. Es decir, es un cuadrado en el que se tiene un eje vertical y otro horizontal, en el que se tiene en un lado probabilidad y en otro las consecuencias.

El mapa de calor es a su vez una matriz de riesgos en la que, en lugar de indicar la probabilidad y consecuencia de un riesgo de forma numérica o con conceptos como “crítico”, “alto”, “bajo”, se hace con colores, típicamente colores cálidos para indicar riesgos altos y colores fríos para indicar riesgos bajos.

Hay que tener en cuenta que el color que se le asigne a un valor de riesgo no es universal sino que depende del “apetito del riesgo” que tenga la organización. Por ejemplo, para una organización un valor

de riesgo de 6 puede ser Muy Alto y pintarse en color rojo para llamar la atención de la alta dirección, y para otra un riesgo de 6 es aceptable y pintarse en color amarillo, como sólo una advertencia sin más. Así pues, puede haber organizaciones en las que todo el mapa esté coloreado en verde, porque todos los riesgos sean tolerables o, inversamente, organizaciones donde una gran parte de los riesgos sean pintados en rojos porque su nivel de tolerancia sea mínimo.

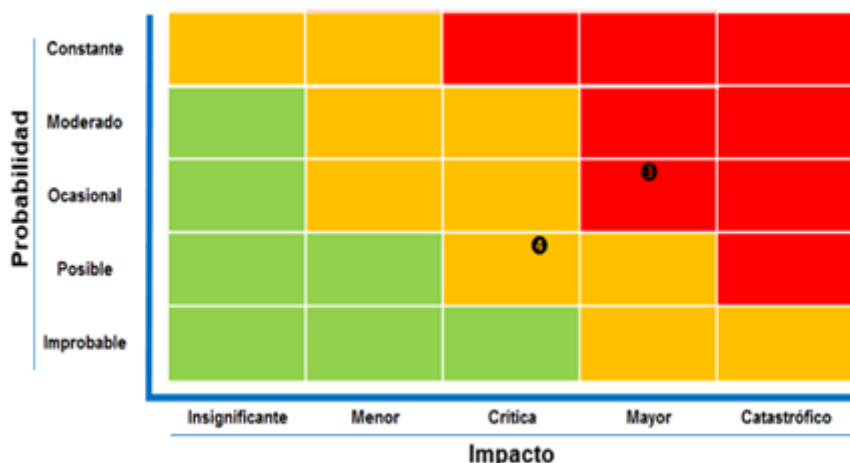


Figura 2: Ejemplo de Mapa de calor de riesgos. Fuente: EALDE.

3.2.6 Cisnes blancos, cisnes grises, cisnes negros y teoría de juegos aplicada al análisis de riesgos adversarios

En teoría de riesgos, los sucesos se dividen en varias categorías según el grado de conocimiento y cálculo de su probabilidad.

Los sucesos que podemos imaginar y conocer su probabilidad se denominan “Cisnes blancos”.

Los sucesos que ni siquiera podemos llegar a imaginar y, por tanto, no los hemos contemplado en nuestro análisis de riesgos se denominan “**Cisnes negros**”.

El investigador Nassim Taleb bautizó así a este tipo de riesgos pues, igual que antes del descubrimiento de Australia todo el mundo daba por hecho que los cisnes eran siempre blancos, a menudo nuestro sesgo cognitivo nos lleva dar por hecho que ciertos sucesos no pueden ocurrir o, simplemente, ni siquiera entran en nuestra imaginación y nuestros cálculos. Sin embargo, hay sucesos no imaginados de altísimo impacto que, una vez que han ocurrido se podrían haber concebido, explicada y hasta quizás predicho.

Los **Cisnes Grises** se diferencian de los Cisnes Negros en que para se pueden conocer y obtener una aproximación sobre la probabilidad de que ocurran y reducir así su efecto sorpresa. Como ya hemos visto anteriormente lo que es un mapa de riesgos, este tipo de riesgo correspondería a los de mayor impacto pero baja probabilidad (o quizás es mejor decir difícil de calcular probabilidad).

De esta forma los Cisnes Grises admiten pronósticos que si bien reducen su incertidumbre, no alcanzan la precisión de las predicciones estadísticas de los Cisnes Blancos.

3.2.7 Pronosticando riesgos a futuro: Los KRI

Los KRI son los indicadores clave de riesgo (Key Risk Indicators), métricas que se utilizan para determinar la posible evolución de un riesgo a futuro y tomar así medidas oportunas antes de que el riesgo aumente a valores no deseables.

Por ejemplo, es posible que el riesgo de acceso no autorizado sobre un sistema a día de hoy se encuentre limitado a un valor aceptable de 2.5 (por debajo de nuestro umbral fijado de 3 por la organización), pero a medida que vamos descubriendo incidentes de acceso no autorizado, descubrimos que la frecuencia asociada a esta amenaza (intrusión) va aumentando. Supongamos que

la amenaza estaba en un 5% hace 10 años, pero ha ido incrementando un 1% de forma anual, de modo que ahora mismo está en un 15%, con un riesgo como comentamos de 2.5. De seguir esta evolución en 3 años tendremos una probabilidad del 18% un riesgo ya de 3. Debemos, pues, tomar acción antes de que el riesgo exceda el umbral fijado.

En el informe anual del estado de la seguridad ligado a la implantación del ENS, el llamado informe INES, recomienda el control de tres indicadores clave de riesgo:

- Indicador de derechos de usuarios (cuántos son administradores de los equipos).
- Indicador de dispositivos propios de usuarios (el uso del BYOD).
- Indicador de rotación de personal en TI.

3.2.8 Otros procesos similares y emparentados con el Análisis de Riesgos

El AR que acabamos de ver tiene algunos elementos comunes con otros procesos importantes para las organizaciones:

- **Análisis de Impacto (BIA):** Primer paso en el establecimiento de un Plan de Continuidad de Negocio (PCN), se centra en la identificación de los tipos de impacto, orientado en conocer qué podría verse afectado y las consecuencias sobre los procesos de negocio que un desastre o interrupción prolongada de servicios podría comportar. Así pues, el BIA se centra en desastres (sucesos mayores) y no en cualquier incidente como es el caso del AR, y además, en un AR se identifican, analizan y valoran las amenazas de seguridad con base en su impacto sobre los activos críticos y la probabilidad de ocurrencia. El BIA no tiene en cuenta las amenazas si no sólo el impacto.
- **Análisis de Riesgos en el RGPD, Evaluación de Impacto en la Privacidad (EIPD):** Análisis de los riesgos para los interesados en los datos de carácter personal a los que las actividades de tratamiento pueden someterles. El matiz diferenciador en este caso frente al AR típico de seguridad es la información estriba en que estamos analizando una dimensión distinta a las típicas de la seguridad de la información, como es en este caso las expectativas de privacidad, a la par que estamos analizando el proceso de tratamiento de los datos y no todos los activos de información de la organización. Es un análisis sutilmente distinto porque está muy enfocado a una finalidad concreta.

3.3 Gestión de Riesgos

La gestión de riesgos es crucial para poder implantar un SGSI ya que se parte del resultado final o **riesgo aceptable por la organización**. Si bien lo ideal sería no asumir ningún tipo de riesgo, esta situación es en la práctica difícil de implementar por no decir que imposible, de modo que todas las organizaciones en mayor o menor medida deben definir cuál es su ***“apetito por el riesgo”, un equilibrio entre lograr la eficacia y eficiencia en el logro de sus objetivos de negocio y el riesgo que pueden asumir para ello. Coloquialmente se trataría de que no cueste más el collar que el riesgo o dicho de otro modo, que el coste de reducir el riesgo a cero no exceda los beneficios que voy a obtener con ello.***

La gestión de riesgos en seguridad de la información/ciberseguridad tiene como objetivo en primer lugar **Analizar los Riesgos y después, una vez analizados aplicar las estrategias que se consideren mejores para reducir los riesgos hasta un nivel asumible por la organización.**

3.3.1 Estrategias de gestión de riesgos

Las estrategias de gestión de riesgos nos permiten decidir cómo vamos a abordar el qué hacer con los riesgos, es la toma de decisión frente al riesgo. Básicamente contamos con las siguientes opciones:

- **Asumir los riesgos:** No se aplica ninguna medida, directamente se acepta el riesgo tal como es. Se puede hacer siempre que el riesgo sea menor o igual que el umbral de riesgo aceptable.
- **Transferir el riesgo:** Se encarga a un tercero la gestión del riesgo, para que se encargue de prevenirlo, eliminarlo o asumir el coste financiero en caso de que el evento negativo ocurra, por

ejemplo, mediante un ciber-seguro que cubra los daños en caso de materializarse el riesgo. Hay que indicar que no siempre es una estrategia aceptable, en caso de daños intangibles o inasumibles (vidas humanas por ejemplo, reputación, etc.) ya que el tercero nunca es dueño de este tipo de riesgos, sino sólo de los daños económicos.

- **Mitigación o reducción del riesgo:** Se aplican controles y medidas para reducir el riesgo, bien reduciendo la ocurrencia de las amenazas, o bien minimizando el daño de la materialización de las mismas (reducción del impacto).

3.3.2 Riesgo residual

El riesgo residual es el riesgo resultante tras aplicar las estrategias de gestión de riesgo. Debe resultar siempre menor que el umbral de riesgo fijado como aceptable (apetito por el riesgo).

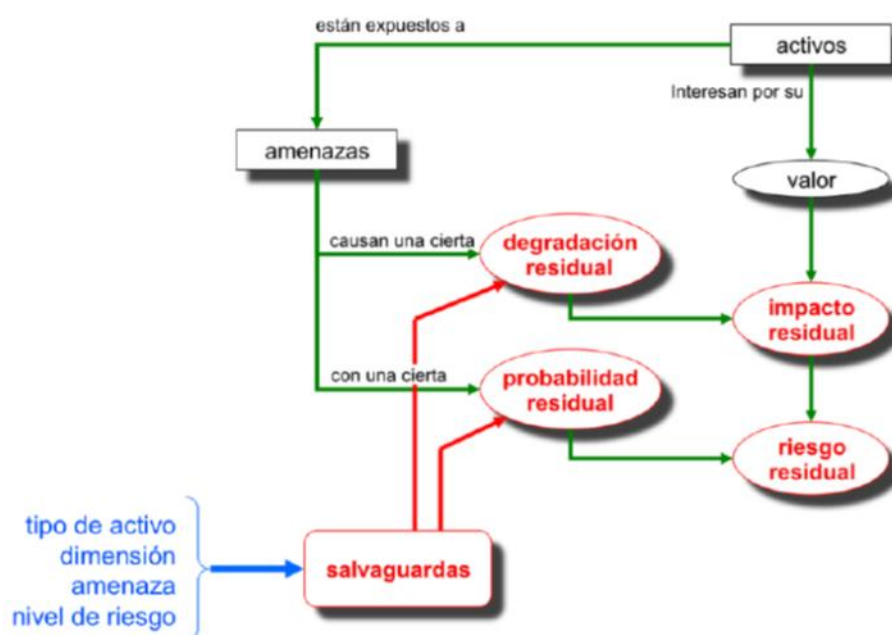


Figura 3: Riesgo residual según MAGERIT

3.3.3 Selección de las salvaguardas/contramedidas

La aplicación de salvaguardas o contramedidas es una labor de suma importancia ya que debe sopesarse siempre su eficacia (logro del objetivo), su eficiencia (coste y rendimiento) y su aplicabilidad real en la organización.

Además, la implantación de determinadas medidas puede suponer poner “patas arriba” literalmente una organización o realizar un desembolso inasumible.

Cualquier implantación de salvaguardas, además, debe contar con un sistema de métricas para medir el grado de avance y de eficacia de las mismas.

Sin embargo, y siguiendo los esquemas de Pareto, el 20% de esfuerzo a menudo logra el 80% de eficacia a la hora de planearse un Plan de Tratamiento de los Riesgos (PTR).

A la hora de seleccionar las salvaguardas hay que tener en cuenta lo siguiente:

- Tipo de control al que pertenece la salvaguarda:

- **Organizativa:** Por ejemplo, introducir y difundir un procedimiento para controlar un acceso, por ejemplo mediante una lista de personal autorizado que se le suministre al personal encargado de la seguridad.
- **Personal:** Por ejemplo, concienciar al personal en la necesidad de cerrar con llave al salir del despacho y depositar la llave a buen recaudo.
- **Física:** Por ejemplo, instalar una cerradura con llave en un despacho.
- **Técnica:** Por ejemplo, cifrar con *bitlocker* un portátil que vaya a salir fuera de las oficinas.
- **Objetivo de la salvaguarda (Prevenir, Reducir, eliminar, etc.):**
 - **Preventiva:** Previenen un riesgo, por ejemplo, instalar una cerradura con llave.
 - **Detectiva:** Detectan que se está produciendo un incidente a fin de avisar y que se pueda controlar el incidente en curso, como por ejemplo, instalar una alarma de detección de humos.
 - **Correctiva:** Actúan sobre el incidente producido para acotar o minimizar el impacto. Por ejemplo, un sistema de extinción de incendios.

efecto	tipo
preventivas: reducen la probabilidad	[PR] preventivas [DR] disuasorias [EL] eliminatorias
acotan la degradación	[IM] minimizadoras [CR] correctivas [RC] recuperativas
consolidan el efecto de las demás	[MN] de monitorización [DC] de detección [AW] de concienciación [AD] administrativas

Figura 4: Tipos de salvaguardas según la metodología MAGERIT

4 Metodologías de análisis y gestión de riesgos

A continuación revisaremos algunas metodologías más importantes para la Gestión de Riesgos recalando en la que más nos interesa para la Administración como es la metodología MAGERIT.

4.1 MAGERIT

MAGERIT es el acrónimo de *“Metodología de análisis y gestión de riesgos de IT”* elaborada en su día por el antiguo Consejo Superior de Administración Electrónica y actualmente mantenida por la Secretaría General de Administración Digital (Ministerio de Asuntos Económicos y Transformación Digital) con la colaboración del Centro Criptológico Nacional (CCN). Adicionalmente, MAGERIT está en el catálogo de herramientas propuesto por ENISA.

A diferencia de las normas ISO, MAGERIT es gratuita y se puede consultar tanto en el portal de Administración Electrónica (más conocido como PAE) como en la página web del CCN (ver bibliografía).

Los objetivos que persigue esta metodología principalmente son:

- **Concienciar** a los responsables de las organizaciones de información de la existencia de riesgos y de la necesidad de gestionarlos.
- Ofrecer un **método sistemático** para analizar los riesgos derivados del uso de tecnologías de la información y comunicaciones (TIC).
- Ayudar a **descubrir y planificar el tratamiento** oportuno para mantener los riesgos bajo control.

Adicionalmente, MAGERIT ayuda a la preparación de la certificación de la organización en el SGSI de referencia, en este caso el ideal sería el ENS, dado que MAGERIT v.3 está perfectamente alineado con el mismo.

4.1.1 Organización de la documentación de MAGERIT

MAGERIT versión 3 se organiza en tres libros:

- **Método:** Se centra en el proceso de Análisis y Gestión de Riesgos, dando consejos además para implementar el Plan de Tratamiento de Riesgos.
- **Catálogo de Elementos:** Explica en detalle los elementos típicos del AR tales como los Activos y sus tipos, las dimensiones de seguridad para la valoración, la valoración de los activos, las amenazas y las salvaguardas.
- **Guía de Técnicas:** Proporciona información sobre las técnicas más comunes en el AR y la gestión de riesgos: Análisis mediante tablas, árboles de ataque, análisis algorítmico, técnicas generales, técnicas gráficas, sesiones de trabajo y entrevistas, valoración Delphi.

4.1.2 Implementación de la metodología

Los pasos para la implementación de esta metodología son los siguientes:

Fase I: Análisis.

1. Levantamiento del Mapa de Activos, en especial considerando los Activos Esenciales. De este modo, obtendremos los activos que posee la organización clasificados de acuerdo a su función.
2. Valoración de activos. Es la valoración asignada al activo de acuerdo a la criticidad y teniendo en cuenta las cinco dimensiones de seguridad.
3. Identificación de las amenazas y su frecuencia

4. Identificación del Impacto de las amenazas sobre los activos.
5. Cálculo del Riesgo. Es la probabilidad de materialización de amenazas sobre el activo.

Fase II: Tratamiento

6. Identificación y valoración de salvaguardas.
7. Cálculo del Riesgo residual. Si es aceptable, se finaliza. Si no, se repite el paso 6.

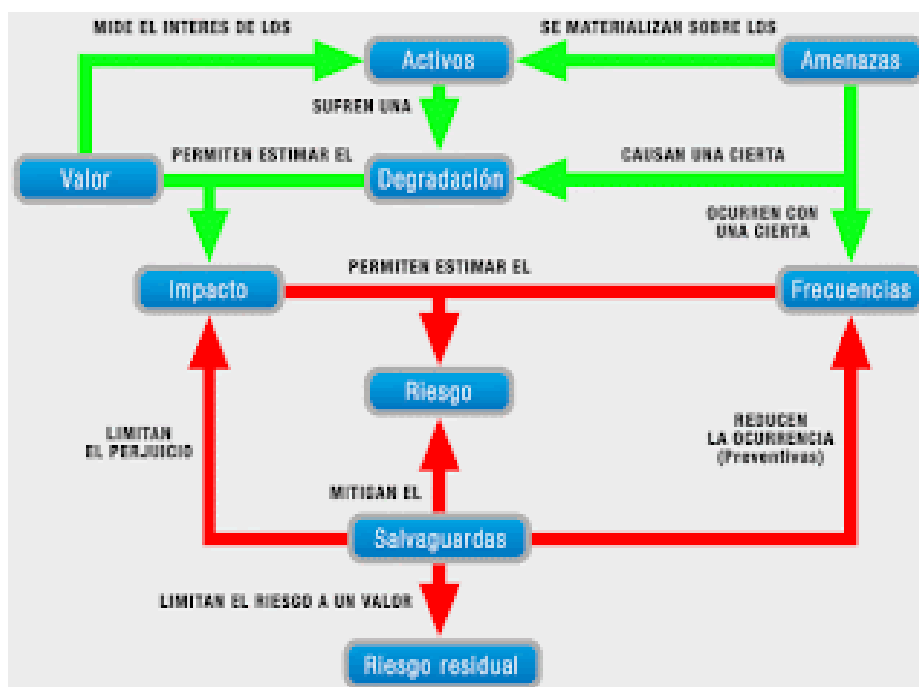


Figura 5: Resumen de la Gestión del Riesgo según la Metodología MAGERIT.

La figura anterior resume el proceso de Análisis de Riesgos (AR) siguiendo la metodología MAGERIT:

Los activos (de información) son el eje del AR, y el proceso comienza midiendo el valor que tienen para nuestra organización (recordemos que la valoración se realiza atendiendo a las cinco dimensiones de seguridad típicas).

Las amenazas, cuando se materializan (con una determinada frecuencia/probabilidad) sobre los activos los degradan, provocando un impacto (daños) en la organización. Este daño es proporcional al valor que tiene el activo y el grado de degradación sufrido.

El riesgo (potencial) por tanto se calcula en función de la frecuencia de las amenazas y el impacto producido. Si al riesgo potencial le restamos el efecto de las salvaguardas (también llamadas contramedidas) ya implantadas lo que obtenemos es el **riesgo actual**.

Las salvaguardas actúan bien reduciendo la probabilidad de ocurrencia de las amenazas (salvaguardas preventivas) o bien reduciendo el impacto (mitigadoras).

De este modo el riesgo resultante llamado **riesgo residual** es el resultado de restarle al riesgo potencial el beneficio de las salvaguardas aplicadas al estado del **riesgo actual**.

De este modo podemos decir, que, de mayor a menor el riesgo sería como sigue:

- Riesgo potencial, riesgo actual, riesgo residual.

4.2 Otras metodologías

La norma **ISO/IEC 27005:2018** no proporciona una metodología concreta de Análisis y Gestión de Riesgos, sino que describe el proceso que se debe seguir paso por paso. Es muy similar a MAGERIT.:

1. Establecimiento del contexto
2. Evaluación del riesgo
3. Tratamiento del riesgo
4. Comunicación del riesgo
5. Monitorización y revisión del riesgo

La serie **NIST SP-800-37** “Guía para aplicar el marco de gestión de riesgos a los sistemas de información federales” es la seguida por las autoridades gubernamentales en Estados Unidos para evaluar riesgos en ciberseguridad y en la privacidad.

CRAMM (CCTA Risk Analysis and Management Method), desarrollada por la antigua agencia de Telecomunicaciones británica BSI fue la más seguida por instituciones tales como la OTAN.

MEHARI (MEthod for Harmonized Analysis of Risk), comúnmente utilizada en organismos públicos en Francia y Canadá.

Octave, diseñada por la Carnegie Mellon University, SEI (Software Engineering Institute), fue muy extendida hace años por el patrocinio que le hizo ISACA.

La norma **ISO 31000:2018** aborda también la gestión de riesgos pero desde el prisma de la continuidad de negocio y no de la seguridad de la información.

En la versión de la ISO 27001 del año 2013 se hacía mención a la norma ISO 31000 para los aspectos relacionados la Gestión de Riesgos de forma estratégica y global, si queremos implantar un Sistema para la Gestión de la Continuidad de Negocio de forma conjunta con el Sistema de Gestión de la Seguridad de la Información.

5 Herramientas para la gestión de riesgos

Tan importante como contar con una buena metodología de gestión de riesgos es conseguir la automatización del proceso mediante el uso de herramientas adecuadas.

A continuación ofreceremos una pincelada de las más usadas en ámbitos institucionales así como la forma de usarlas y los casos de uso más frecuentes.

5.1 Suite de herramientas EAR/PILAR

Desde que en el año 2002 el profesor José Antonio Mañas idease la herramienta Chinchón, mucho ha evolucionado la suite de herramientas de análisis de riesgos de carácter institucional que se ofrecen gratuitamente a la Administración a través de licenciamiento gestionado por el CCN.

Es importante mencionar que los ficheros generados con la herramienta PILAR pueden integrarse con las herramientas INES y AMPARO, dado que ambas cuentan con interfaz para la importación de datos.

PILAR dispone de una biblioteca estándar de propósito general, y se puede realizar análisis de riesgos y de cumplimiento de seguridad respecto de las dos normas más habituales: ENS y la ISO 27001.

(Como se verá en el tema siguiente, existen muchas similitudes entre ambas si bien los enfoques y el propósito son diferentes).

5.1.1 PILAR basic y μ PILAR

PILAR basic es una versión sencilla indicada para la PYME y Administración local. Simplifica el levantamiento del mapa de activos, la selección de amenazas y de salvaguardas para poder abordar en pocos pasos un análisis de riesgos completo.

μ PILAR, por otra parte, es la versión más reducida de la herramienta PILAR, indicada para abordar un análisis de riesgos muy rápido. El resultado del análisis puede cargarse luego en PILAR para mejorarlo o detallarlo.

5.1.2 Configuración de la herramienta PILAR

Al abordar un proyecto de análisis de riesgos es preciso tomar una serie de decisiones importantes:

Principalmente si vamos a abordar un análisis cualitativo o cuantitativo. Si no se conoce con exactitud el valor económico o de las pérdidas posibles ligadas a activos es mejor abordar el análisis cualitativo donde el riesgo se proporciona en una escala de gradación típicamente del 0 al 10.

1. Las fases con las que vamos a abordar la gestión del riesgo.
2. Amenazas, si vamos a valorarlas por su frecuencia/probabilidad y si vamos a seleccionarlas manualmente o de forma automática (las sugiere PILAR en función del tipo de activos, es menos detallista pero más idóneo para principiantes).
3. Valoración del impacto (porcentaje, degradación, etc.)
4. Salvaguardas, nivel o madurez.

5.1.3 Obtención e instalación de las herramientas PILAR

Sea cual sea la herramienta PILAR seleccionada para abordar nuestro Análisis de Riesgos, debemos descargarnos el software del portal del CCN:

<https://loreto.ccn-cert.cni.es/index.php/s/ZLjgMqlsF8yLSPh/authenticate>

Clave: PILAR.

Descargamos la versión que necesitamos, según el estándar elegido, ISO 27001 o ENS. Lo más habitual es este último.

Para instalar PILAR debemos tener instalada la Máquina virtual de Java (últimas versiones) y disponer de permisos de administrador sobre el equipo. PILAR se puede instalar tanto sobre Windows como sobre Linux, y funciona en modo Applet.

Debemos escribir al CCN para que nos proporcione el fichero de licencia correspondiente y poder así generar archivos nuevos, que tendrán extensión “mgr”.

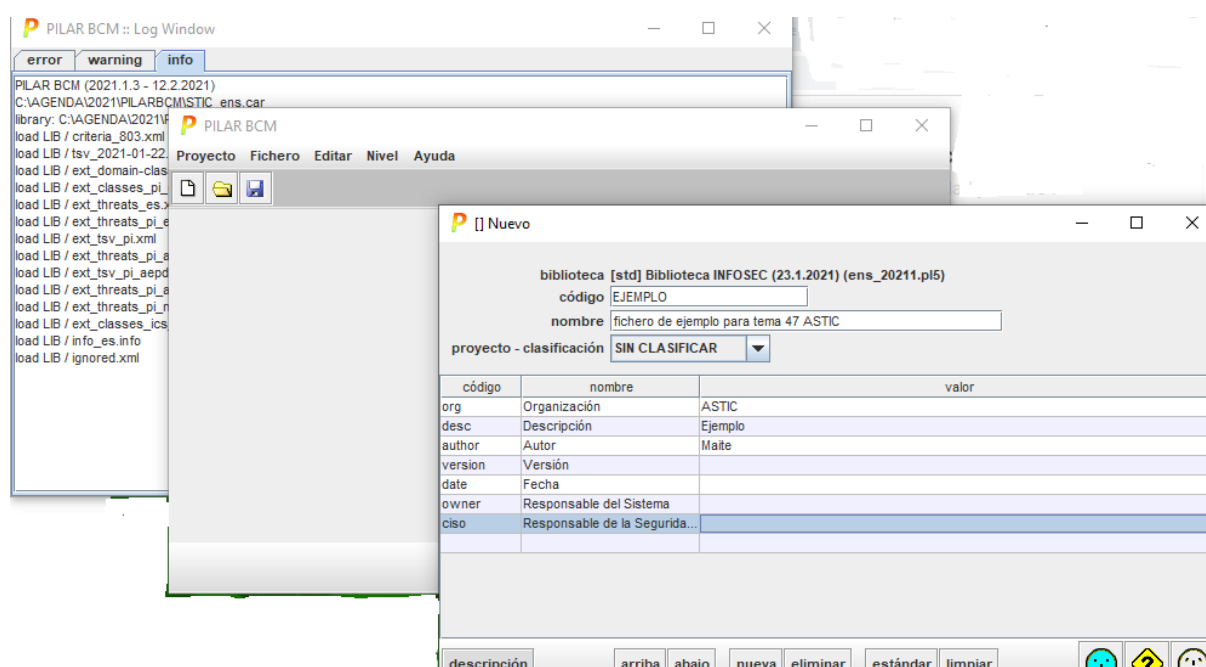


Figura 6: Ejemplo de fichero nuevo abierto con la herramienta PILAR

5.2 Otras herramientas para implementar un AR

Además de la archiconocida PILAR, actualmente contamos con una cohorte de herramientas para implementar análisis de riesgos. Daremos una pincelada de las más conocidas en la actualidad.

A menudo se presentan bajo el nombre genérico de herramientas RM (Risk Management) o dentro de una Suite **GRC** (Governance, Risk and Compliance).

- **Global Suite:** Al igual que PILAR, permite abordar un análisis de riesgos, gestión de riesgos y presentar un cuadro de mandos para la dirección. Funciona de forma más intuitiva que PILAR y es más amigable para novatos, pero requiere del pago de una licencia que no es gratuita para la Administración a diferencia de pilar.
- **SAP GRC:** Como punto fuerte, se integra con el proceso de auditoría formal, ya que requiere proveer de evidencia del establecimiento de los controles en el análisis de riesgos. Además, se

integra de forma fácil con soluciones ERP corporativas. Punto débil, difícil de ajustar a marcos de gobierno de la seguridad de la información ligados a controles muy técnicos tales como la ISO 27002 o el ENS.

- **SAI 360 (antiguamente BWISE):** Modular, automatizado y preconfigurado con los controles típicos para cada industria. Es más versátil que SAP GRC pero la curva de aprendizaje hacen difícil su aplicación en la práctica en la Administración.
- **Ventiv IRM:** Dirigido a múltiples sectores y ubicado en la Nube, se proporciona como solución Saas.

5.3 Guías CCN-CERT y otros recursos que aplican en la gestión de riesgos

A continuación, se indican las guías que se recomienzan consultar para implantar un proyecto de gestión de riesgos:

- Entrada a la guía de recursos de la herramienta PILAR: <https://pilar.ccn-cert.cni.es/index.php/recursos/guias-manuales>:

CCN-STIC-470I1 PILAR - Manual de Usuario v7.1

CCN-STIC-470I2 PILAR - Continuidad Manual de Usuario v7.1

CCN-STIC-472G PILAR Basic - Manual de Usuario v7.1

CCN-STIC-473F µPILAR - Manual de Usuario v7.1

- **Guía general, del año 2018, de la herramienta PILAR versión 7** (debe actualizarse ya que hay una nueva versión del año 2021 ya en curso):
<https://www.ccn-cert.cni.es/pdf/guias/series-ccn-stic/guias-de-acceso-publico-ccn-stic/2841-ccn-stic-470i1-pilar-manual-de-usuario-v7-1/file.html>
- **Guía CCN-STIC 882 de Análisis de Riesgos para Entidades Locales:** Publicada en junio del 2019, esta guía desarrolla el proceso de Análisis y Gestión de Riesgos utilizando la herramienta Micro PILAR paso a paso, de manera que sirva de ayuda guiada para las personas responsables de realizar este análisis de riesgos en una Entidad Local para el cumplimiento del Esquema Nacional de Seguridad (ENS) y el Reglamento General de Protección de Datos (RGPD). Se puede consultar en: <https://www.ccn-cert.cni.es/pdf/guias/series-ccn-stic/800-guia-esquema-nacional-de-seguridad/3803-ccn-stic-882-guia-de-analisis-de-riesgos-para-entidades-locales/file.html>

Por último, en la plataforma de formación del CCN llamada “*Angeles*” podemos encontrar un curso muy interesante sobre análisis de riesgos de aplicación en el ENS:

<https://angeles.ccn-cert.cni.es/index.php/es/menu-formacion-es/cursos-online-ccn-ciberseguridad-menu-es>

6 Implementación paso a paso de un análisis de riesgos con MAGERIT/PILAR

A continuación se detallará cómo se debe llevar a cabo un Análisis de Riesgos implementado con Metodología MAGERIT y la herramienta PILAR.

6.1 Levantamiento del mapa de activos y su valoración

Para empezar, debemos determinar el alcance de nuestro análisis de riesgos, si va a abarcar nuestra organización al completo o va a ser estudiada por piezas más pequeñas que necesitemos analizar individualmente (por ejemplo, sedes o delegaciones provinciales). **En ese caso, partiremos los activos en Dominios.**

Un Dominio es un conjunto de información (activos, amenazas, salvaguardas) para los que se quiere hacer un análisis particularizado del riesgo.

Por defecto, usaremos un solo dominio, el llamado DOMINIO BASE.

Si usamos MAGERIT/PILAR, podemos jugar con los dominios, puesto que, si tenemos varios análisis realizados por dominios y hemos generado así n ficheros, podemos crear un fichero con un dominio base que aglutine los n dominios. Esta operación, aunque da mucho juego, no es fácil y requiere de mucha experiencia tanto en el análisis de riesgos como con la herramienta PILAR.

Los activos esenciales son aquellos procesos de negocio, servicios o datos vitales para el funcionamiento de la organización como tal. Así, por ejemplo, un supermercado tendrá como activos esenciales el proceso de ventas en tienda (activo esencial de tipo proceso de negocio), ligado al activo esencial línea de cajas (servicio) y a los datos de transacciones de venta registrados en los PoS (cajeros) que son datos vitales para el negocio.

Estos tres aspectos de lo que se considera un activo esencial (procesos de negocio, servicios y datos vitales) son importantes a la hora de levantar el mapa de activos.

En el ejemplo anterior, ligado también al proceso de ventas podríamos tener el servicio de venta online, con datos esenciales las transacciones web o base de datos de venta online, diferenciada en este caso de los datos de los cajeros de las tiendas.

Las capas de activos son sólo contenedores o conjuntos de activos organizados para la mejor gestión de los activos, pero per sé no añaden información u operativa adicional.

Típicamente, la herramienta PILAR propone unas por defecto, pero podemos usar otras diseñadas a nuestra conveniencia.

Es importante realizar el ejercicio de considerar qué activos dependen de qué otros activos. *Para un buen Análisis de riesgos, es importante hacer depender activos de capas de niveles superiores de activos de la capa inmediatamente inferior.*

Las capas superiores estarán formadas por los datos, los servicios y por encima de todo, los procesos de negocio.

Las capas de niveles más bajos son los locales, las personas, el equipamiento y los servidores y comunicaciones de base.

Las capas del nivel justo por encima son las redes y las aplicaciones de servicios esenciales tales como el servicio de DNS, de correo, de conexión o acceso remoto, etc.

Las capas justo por encima son las de aplicaciones más complejas, desarrolladas en propio o no comerciales.

Es muy importante indicar que **no se debe usar la herramienta PILAR y el Análisis de Riesgos como si de un inventario de activos se tratase**. No es preciso indicar al detalle todo el parque de activos (equipamiento, servidores, racks, etc). que tenemos, sino ser muy precisos indicando cuáles son activos esenciales y el grupo de activos por debajo del que dependen.

Una vez tengamos los activos identificados, debemos proceder a valorarlos por las dimensiones de seguridad, MAGERIT ofrece una escala entre 0 y 10. Para ello valoraremos los dominios o bien los activos directamente según cómo se haya especificado que vamos a abordar el Análisis de Riesgos.

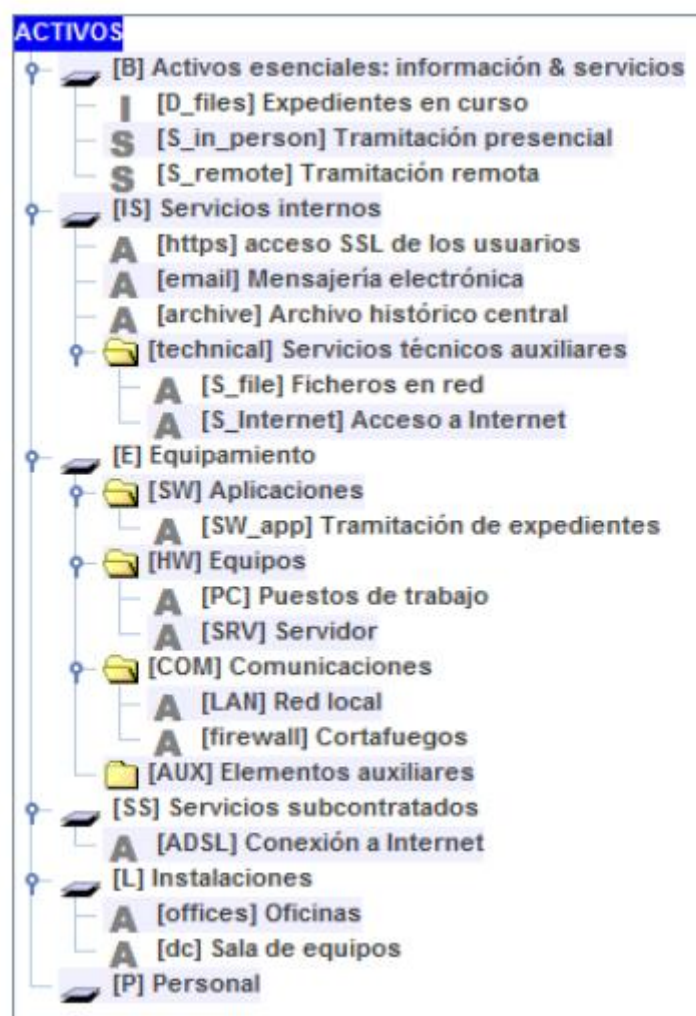


Figura 7: Capas de activos sugeridos por la herramienta PILAR. Fuente: Manual de Pilar 2021 (ver bibliografía).

6.2 Identificación y valoración de las amenazas por su probabilidad

Una vez tengamos trabajado el mapa de activos, debemos pasar a analizar las amenazas. Como ya hemos mencionado anteriormente, podemos añadir la opción de modelar el Perfil del Atacante, pues centrará las amenazas en aquellas que son típicas de este perfil.

Por ejemplo, supongamos que nuestro enemigo típico es el *hacktivista* por motivos políticos, el análisis de riesgos nos centrará las amenazas en aquellas habituales de este perfil tales como los Ataques de Denegación de Servicio Distribuido (*DDoS*), intrusiones en la red perimetral, intentos de acceso físico, ingeniería social, etc. Si, por el contrario, el enemigo típico es el empleado descontento, ya que sabemos que nuestra organización está viviendo una convulsión interna, las amenazas típicas serán la revelación de información confidencial a la prensa, el sabotaje, las huelgas, etc.

Una vez identificadas y seleccionadas las amenazas, hay que indicar cuál es su probabilidad/frecuencia.

6.3 Análisis y evaluación del riesgo

Una vez hemos terminado la fase de análisis, es preciso determinar si el riesgo resultante es admisible o no por nuestra organización.

Si usamos la herramienta PILAR con la referencia del ENS, existe una columna donde se nos indica los valores de riesgo recomendados para el cumplimiento con dicho ENS.

6.4 Estado de las salvaguardas

PILAR sugiere una serie de salvaguardas posibles, que debemos incorporar o no a nuestra gestión del riesgo, en lo que se conoce como Declaración de Aplicabilidad. Para el caso del ENS esta aplicabilidad no es opcional sino automatizada siguiendo el ANEXO II de dicho ENS. Si seguimos otros estándares, entonces sí podemos eludir las recomendaciones efectuadas bajo nuestro criterio.

Cuando una salvaguarda consideramos que no es de aplicación a nuestro sistema (por ejemplo, se nos indica un balanceador entre nuestros CPDs cuando sólo contamos con uno, podemos indicarlo mediante la selección de “No Aplica”.

Su madurez sigue el estándar del CMM siguiendo los siguientes criterios de madurez (ejemplos tomados de la guía del CCN-STIC 882):

- **L0. Medida Inexistente.** Esta medida no está siendo aplicada en este momento. Por ejemplo, si la medida se refiere a “hacer backups”, estamos en el nivel en el que no se hacen backups de ningún tipo.
- **L1. Inicial / ad hoc.** Estamos todavía intentando implantar la salvaguarda pero no funciona de forma habitual. Por ejemplo, se hace backup cuando el técnico se acuerda.
- **L2. Repetible, pero intuitivo.** Cuando existe un mínimo de planificación que, acompañada de la buena voluntad. Es impredecible el resultado si se dan circunstancias nuevas. Por ejemplo, seguimos con los backups. Se hacen todas las semanas, pero si el técnico está de vacaciones no se hacen.
- **L3. Proceso definido.** Se dispone un catálogo de procesos que se mantiene actualizado. Estos procesos garantizan la consistencia de las actuaciones entre las diferentes partes de la organización. Por ejemplo, seguimos con los backups. Existe un procedimiento documentado de backups que es conocido por todos los técnicos, y si falta el encargado de los backups, otro técnico, con la ayuda del procedimiento, los puede realizar.
- **L4. Gestionado y medible.** Cuando, además de lo anterior, se dispone de un sistema de medidas y métricas para conocer el desempeño (eficacia y eficiencia) de los procesos. Por ejemplo, seguimos con los backups. Se revisan los logs, se hacen pruebas de restauración y se hacen mediciones de tiempos de backup para ajustar las ventanas de copia.
- **L5. Optimizado.** En este nivel la organización es capaz de mejorar el desempeño de los sistemas a base de una mejora continua de los procesos basada en los resultados de las medidas e indicadores. Por ejemplo, siguiendo con el ejemplo de los backups: se revisan las mediciones, los resultados de prueba y el propio procedimiento, para determinar aspectos de mejora que se documentan, planifican, implementan y se evalúan.

Al final obtendremos lo que PILAR denomina “Informe de insuficiencias” si, fijado un umbral de madurez mínimo, queremos obtener qué salvaguardas se encuentran por debajo de un determinado umbral.

Cuanto menos madura sea una salvaguarda, mayor será el valor del riesgo, pues su poder mitigador será menor al ser menor su eficiencia.

6.5 Selección de las salvaguardas

Una vez sabemos el estado de las salvaguardas y las opciones de mejora, determinamos sobre qué salvaguardas vamos a actuar, cómo vamos a mejorar su nivel y prepararemos un plan. Las salvaguardas se seleccionan en la parte de gestión del riesgo,

Típicamente, el cumplimiento del ENS pide que para sistemas de categoría Básica tengamos un nivel de madurez de las salvaguardas mínimo de L2, categoría Media de L3 y Alta de L4, pero sólo para aquellas salvaguardas que aporten significativamente para la categorización del sistema.

Esto es, si un sistema tiene categoría alta porque su disponibilidad así está valorada, siendo sin embargo su confidencialidad de nivel bajo, no tiene sentido mitigar riesgos para cumplir con el ENS

aportando salvaguardas que reduzcan riesgos en la confidencialidad si esta ya está a un nivel L2, sino que haríamos mejor en seleccionar salvaguardas para garantizar una disponibilidad a nivel L4, como por ejemplo, la que hemos apuntado para el tema de los backups, como es hacer pruebas de restauración y medición de tiempos de backup. Pero no sería muy indicado, por ejemplo, cifrar la base de datos, ya que no aporta un menor valor del riesgo, si tenemos el sistema ya protegido con medidas L2 para confidencialidad, como, por ejemplo, control de acceso a ficheros, usuario y contraseña, etc.

7 RESUMEN ESQUEMÁTICO

- El conocimiento basado en la información es el activo más importante con el que cuentan las organizaciones y es preciso protegerlo frente a amenazas y vulnerabilidades.
- La Seguridad de la Información comprende no sólo la seguridad de los sistemas TI donde se alberga o las redes donde transita, sino de todas sus formas de expresión, almacenamiento y comunicación, incluyendo soportes analógicos tradicionales tales como el papel o incluso la comunicación oral de la misma.
- La ciberseguridad es el conjunto de actividades dirigidas a proteger el ciberespacio contra el uso indebido del mismo, defendiendo su infraestructura tecnológica, los servicios que prestan y la información que manejan.
- Actualmente, se consideran equivalentes la ciberseguridad y la seguridad de la información dado que la inmensa mayoría de los sistemas se encuentran de algún modo conectados a Internet o a otras redes atacables.
- Las dimensiones de seguridad más típicamente consideradas son la Confidencialidad, Integridad, Trazabilidad, Autenticidad y Disponibilidad.
- El rol relacionado con la seguridad de la información/ciberseguridad con responsabilidad es el del CISO/RSI. El CSO tiene la responsabilidad de la seguridad corporativa y el CISO se supereditar de algún modo a este último.
- Un Sistema de Gestión de la Seguridad de la Información implementa procesos y controles de seguridad de la información de forma continua en un ciclo de Deming. El SGSI puede implantarse siguiendo normas o estándares. El más común es la ISO 27001:2017 y el más relevante para la Administración es el Esquema Nacional de Seguridad que se verá en detalle en el siguiente tema.
- Para implementar un SGSI es preciso abordar un Análisis de Riesgos, proceso sistemático por el que se evalúan las amenazas sobre los activos de la información y la probabilidad de que dichas amenazas se materialicen y provoquen un daño o impacto.
- El análisis de riesgos basado activos determina las amenazas sobre los activos de información así como el impacto de la materialización de la amenaza sobre los mismos. MAGERIT es una metodología de este tipo.
- El análisis de riesgos basado en escenarios se basa en plantear y analizar distintas situaciones considerando los riesgos que estas pueden representar para la organización.
- Una tendencia moderna de análisis de riesgos es el análisis de adversarios, contando siempre que detrás de las amenazas hay casi siempre un atacante que hay que conocer y valorar en el análisis de riesgos.
- También, más modernamente, los riesgos se califican como cisnes de colores en función del grado de certidumbre que presenten: Cisnes blancos, riesgos que se pueden medir. Cisnes grises no se pueden medir con precisión pero se conocen y cisnes negros, riesgos que ni siquiera se alcanzan a conocer o vislumbrar.
- Los indicadores de clave de riesgo o KRI sirven para anticipar qué ocurrirá a futuro con los riesgos o determinar tendencias de modo que se puedan combatir antes de que se disparen por encima de lo deseable.
- Aunque con ciertas similitudes con el análisis de riesgos, el BIA se centra el impacto y sirve para implementar SGCN y el EPID se centra sólo en los riesgos para los datos de carácter personal.
- El Análisis de riesgos basado en activos típicamente tiene unas fases precisas como son la del levantamiento del mapa de activos con la identificación de los activos y su valoración, la identificación de las amenazas que inciden en los activos y finalmente la estimación de la probabilidad/frecuencia de dichas amenazas. Una vez tengamos todos estos elementos podremos calcular el riesgo potencial del sistema.
- Una vez tengamos medido el riesgo potencial, para conocer el riesgo real debemos reconocer las salvaguardas que ya tenemos implantadas en el sistema junto con su nivel de madurez, para conocer el grado de eficacia de las mismas. El resultado será el riesgo actual al que está sometido el sistema.

- En la gestión de riesgos, debemos seleccionar cuidadosamente las salvaguardas que usaremos para mitigar los riesgos. En el ENS la categoría de los sistemas implica unos niveles mínimos de madurez en las salvaguardas que van a aplicar a las dimensiones de seguridad que inciden en la categorización de los sistemas.
- También en la gestión de riesgos, debemos determinar qué estrategia vamos a utilizar: Mitigar o corregir, transferir a un tercero que se encargue o lo cubra con un seguro o asumir directamente el riesgo.
- Toda vez que tenemos ya el plan de tratamiento de los riesgos con la selección de salvaguardas que aplicaremos o mejoraremos su nivel de madurez, el riesgo final será lo que se denomina “riesgo residual”, que deberá ser siempre menor que el riesgo admisible por la organización (apetito por el riesgo).
- MAGERIT es el acrónimo de “Metodología de análisis y gestión de riesgos de IT” elaborada en su día por el antiguo Consejo Superior de Administración Electrónica y actualmente mantenida por la Secretaría General de Administración Digital (Ministerio de Asuntos Económicos y Transformación Digital) con la colaboración del Centro Criptológico Nacional (CCN). Adicionalmente, MAGERIT está en el catálogo de herramientas propuesto por ENISA.
- La herramienta PILAR patrocinada por el CCN y la SGAD permite implementar de forma automatizada el AR con la metodología MAGERIT y para SGSIs que sigan el ENS o la ISO27001. Esta herramienta es gratuita para la Administración.

8 GLOSARIO

- **0-day:** Ataque contra un sistema basado en el conocimiento de una vulnerabilidad en un componente software del mismo que es desconocida tanto para los usuarios del sistema como para el fabricante del software.
- **Análisis de Riesgos (AR):** Procedimiento sistemático por el cual se puede medir de forma cualitativa o cuantitativa de forma sopesada la probabilidad de que una amenaza se materialice sobre un activo de información ocasionando un daño severo en el mismo por el impacto que la amenaza materializada (incidente o ataque) ha ocasionado.
- **Apetito por el Riesgo:** Cantidad y tipo de riesgo que una organización está dispuesta a asumir.
- **BIA:** Acrónimo de Business Impact Analysis, Análisis del impacto que los desastres o interrupciones pueden ocasionar en el negocio. Primera tarea a abordar en la implantación de un SGCN.
- **BYOD:** Acrónimo de Bring Your Own Device. Política que siguen algunas organizaciones de permitir/fomentar el uso de dispositivos personales para realizar tareas laborales. Durante la pandemia de COVID-19 se fomentó este uso notablemente para implementar el teletrabajo.
- **CDO:** Acrónimo de Chief Data Officer. Responsable a alto nivel de la estrategia de los datos y la información en una organización. Define cómo se van a extraer, transformar, conservar, analizar, asegurar, etc. los datos.
- **CEO:** Acrónimo de Chief Executive Officer. Máximo responsable de una empresa u organización.
- **CCN:** Acrónimo de Centro Criptológico Nacional. Organismo responsable de garantizar la seguridad las Tecnologías de la Información y la Comunicación (TIC) en las diferentes entidades del Sector Público, así como la seguridad de los sistemas que procesan, almacenan o transmiten información clasificada.
- **CTO:** Acrónimo de Chief Technology Officer. Responsable de cómo se van a aplicar las tecnologías en la organización para conseguir los objetivos de negocio. No confundir con el CIO o responsable de TI, que se centra en la gestión de las TI de un modo táctico.
- **CMM:** Acrónimo de Capability Maturity Model. Organismo. Modelo de evaluación de procesos de una organización elaborado por el SEI (centro de investigación y desarrollo patrocinado por el Departamento de Defensa de los Estados Unidos de América y gestionado por la Universidad Carnegie-Mellon).
- **CPD:** Acrónimo de Centro de Proceso de Datos. Lugar donde se ubican los servidores y dispositivos de comunicaciones de una organización, normalmente en un edificio propio o sala diferenciada del resto con las medidas de protección típicas como alimentación de energía o ininterrumpida, refrigeración y climatización, detección y extinción de incendios, control de acceso físico diferenciado del resto del edificio, etc.
- **CISO:** Acrónimo de Chief Information Security Officer. Responsable de planificar, desarrollar, controlar y gestionar las políticas, procedimientos y acciones en seguridad de la información.

- **CSO:** Acrónimo de Chief Security Officer, responsable de la seguridad corporativa. En España se le conoce mejor por la denominación de Director de Seguridad y sus funciones están reguladas por la Ley de Seguridad Privada Ley 5/2014, de 4 de abril de Seguridad Privada.
- **DDoS:** Acrónimo de: Distributed Denial of Service. Un tipo de ataque consistente en el que de infinidad de orígenes maliciosos se lanzan ataques de red de tipo inundación de flujo o volumétricos de peticiones contra los puertos típicos de comunicaciones de un único objetivo expuesto a Internet, para que éste sucumba al no poder gestionar las peticiones. Un ejemplo reciente es el ataque de DDoS que sufrió el portal de desarrolladores Github en el año 2018 que recibió más de 1,35 terabits por segundo, provocando su caída e indisponibilidad a nivel mundial durante unos diez minutos aproximadamente.
- **DORA:** Acrónimo de Digital Operational Resilience Act, Reglamento europeo cuyo objetivo es mejorar la resiliencia de las empresas dedicadas al sector financiero, mediante una mejora en la gestión de los riesgos a los que están expuestos.
- **EAR:** Entorno de Análisis de Riesgos. Conjunto de soluciones y herramientas proporcionadas por el CCN-CERT para implementar el Análisis de Riesgos con Metodología MAGERIT.
- **ENS:** Esquema Nacional de Seguridad. Se verá en profundidad en el siguiente tema, el 48.
- **ISACA:** Acrónimo de Information Systems Audit and Control Association, una asociación internacional que apoya y patrocina el desarrollo de metodologías y certificaciones para la realización de actividades de auditoría y control en sistemas de información. En particular es muy famosa por el marco de gobierno de las TI llamado COBIT.
- **KRI:** Acrónimo de Key Risk Indicators, indicadores de riesgo clave que nos sirven para anticipar qué ocurrirá a futuro con los riesgos o determinar tendencias de modo que se puedan combatir antes de que se disparen por encima de lo deseable.
- **MAGERIT:** Acrónimo de “Metodología de análisis y gestión de riesgos de IT” elaborada en su día por el antiguo Consejo Superior de Administración Electrónica y actualmente mantenida por la Secretaría General de Administración Digital (Ministerio de Asuntos Económicos y Transformación Digital) con la colaboración del Centro Criptológico Nacional (CCN). Adicionalmente, MAGERIT está en el catálogo de herramientas propuesto por ENISA.
- **NIS2:** Nueva versión de la Directiva europea NIS que entrará en vigor en breve (de momento se ha liberado como borrador). El objetivo primordial de esta modificación de la directiva NIS es la de eliminar las diferencias entre los requisitos de ciberseguridad y de aplicación de las medidas entre los distintos Estados miembros. Para más información se recomienda consultar el siguiente tema, el 48.
- **PDSI:** Plan Director de Sistemas de la Información. La norma ISO 27001 establece que, para implementar de forma efectiva las medidas de seguridad contempladas en el SGSI, se debe elaborar un plan que contenga un horizonte temporal y una serie de hitos alcanzables en dicho horizonte así como las herramientas para medir el grado de evolución de dichas implantaciones.
- **PILAR:** Acrónimo de Procedimiento Informático Lógico de Análisis de Riesgos. Herramienta patrocinada por el CCN y la SGAD que implementa de forma automatizada el análisis de riesgos con la metodología MAGERIT.
- **PTR:** Acrónimo de Plan de Tratamiento de Riesgos. Proceso sistematizado de selección priorizada de salvaguardas para la reducción del riesgo hasta niveles aceptables por la organización. El PTR debe incluir además un plan concreto sobre cómo se implementarán dichas salvaguardas que puede acabar siendo añadido al PDSI.

- **RSI:** Responsable de Seguridad de la Información. Figura aparecida en el RD 43/2021 de desarrollo del RDL 12/2018 que traspone la directiva NIS. Es equivalente al CISO.
- **SGSI:** Acrónimo de Sistema de Gestión de la Seguridad de la Información. Proceso para la implementación de forma continua y en ciclo de Deming de la seguridad de la información.
- **SGCN:** Acrónimo de Sistema de Gestión de la Continuidad de Negocio. Proceso para la implementación de forma continua y en ciclo de Deming de la continuidad de negocio con tareas tales como la elaboración del BIA, la elaboración de planes de contingencia, de recuperación ante desastres, de crisis para determinar roles y responsabilidades, de formación, de comunicación, etc. Se verá en mayor profundidad en otro tema.
- **TI:** Acrónimo de Tecnologías de la Información.

9 TEST

9.1 PREGUNTAS DE TEST

- 1) La medida de guardar la información sensible en papel bajo llave custodiada se puede considerar una medida de:
 - a) Ciberseguridad.
 - b) Seguridad de redes y comunicaciones.
 - c) Seguridad de las TIC.
 - d) Seguridad de la Información.
- 2) Elaborar la política de seguridad de la información, difundirla y aconsejar medidas para su cumplimiento es responsabilidad del:
 - a) Administrador de Seguridad.
 - b) CSO.
 - c) CISO o RSI.
 - d) CEO.
- 3) La diferencia entre amenaza y vulnerabilidad... Señala la respuesta correcta.
 - a) Una amenaza puede tener impacto si se materializa mientras que una vulnerabilidad no.
 - b) Una amenaza es un factor externo que acecha a un activo mientras que una vulnerabilidad es una debilidad interna al activo, pero ambas pueden suponer un riesgo.
 - c) Las vulnerabilidades no pueden mitigarse o corregirse mientras que las amenazas sí.
 - d) Las vulnerabilidades se detectan por un aviso de tipo 0-day pero no suponen un riesgo mientras que las amenazas no las conocemos porque dependen del atacante pero sí suponen un riesgo.
- 4) La diferencia entre riesgo e impacto estriba en que... Señala la respuesta correcta.
 - a) El riesgo es cualitativo mientras que el impacto es cuantitativo.
 - b) El riesgo es la probabilidad de la amenaza que provoca el impacto.
 - c) El riesgo tiene en cuenta la probabilidad de ocurrencia del suceso así como de su impacto y pondera ambos, de modo que $\text{Riesgo} = \text{Probabilidad} \times \text{Impacto}$ mientras que el Impacto sólo establece el daño ocasionado sin más.
 - d) El riesgo indica la cuantía material del impacto producido.
- 5) En análisis de riesgos, ¿qué se considera un "cisne negro"?
 - a) Un riesgo de muy bajo impacto y de escasa frecuencia.
 - b) Un riesgo de muy alta probabilidad pero bajo impacto.
 - c) Un riesgo que ni siquiera se podría suponer pero que tampoco se debería haber tenido en cuenta porque su impacto es muy bajo.
 - d) Un riesgo que no se tuvo en cuenta al realizar el Análisis de Riesgos y que nunca había sucedido antes ni era fácil de suponer pero que una vez ocurrido el impacto ha sido elevadísimo.
- 6) El color asignado a un riesgo en un mapa de calor depende de:
 - a) El apetito por el riesgo de la organización.
 - b) La probabilidad del riesgo.
 - c) El impacto del riesgo.
 - d) La importancia de la amenaza.

- 7) Un indicador clave de riesgo contemplado en el informe INES es... Indica la respuesta incorrecta.
- a) El número de Administradores de Seguridad.
 - b) Los dispositivos BYOD.
 - c) Los derechos de los usuarios.
 - d) La rotación del personal de TI.
- 8) Ordena de mayor a menor los siguientes valores de riesgos:
- a) Riesgo residual, riesgo actual, riesgo potencial.
 - b) Riesgo potencial, riesgo actual, riesgo residual.
 - c) Riesgo actual, riesgo residual, riesgo potencial.
 - d) Riesgo actual, riesgo potencial, riesgo residual.
- 9) El estado de las salvaguardas se mide por:
- a) Su nivel de madurez, siguiendo el modelo CMM con una escala de 0 a 5.
 - b) Su nivel de madurez, siguiendo el modelo CMM con una escala de 1 a 5.
 - c) Por su porcentaje de implantación, de 0 a 100.
 - d) Por el porcentaje de reducción del impacto sobre la amenaza a la que aplican.
- 10) Si queremos implementar un AR completo en una entidad local pequeña, sin incurrir en gastos de licenciamiento, deberemos usar preferiblemente:
- a) CHINCHÓN.
 - b) PILAR 4.
 - c) PILAR BASIC.
 - d) SAP GRC.

9.2 SOLUCIONES A LAS PREGUNTAS DE TEST

PREGUNTA	SOLUCIÓN
1	<i>d</i>
2	<i>c</i>
3	<i>b</i>
4	<i>c</i>
5	<i>d</i>
6	<i>a</i>
7	<i>a</i>
8	<i>b</i>
9	<i>a</i>
10	<i>c</i>

10 BIBLIOGRAFÍA BÁSICA

10.1 BIBLIOGRAFÍA BÁSICA

1. <https://www.aenor.com/certificacion/tecnologias-de-la-informacion/seguridad-informacion>
Norma ISO 27001:2017 para implementar Sistemas de Gestión de Seguridad de la Información.
2. https://www.boe.es/diario_boe/txt.php?id=BOE-A-2021-1192 RD 43/2021 por el que se desarrolla el Real Decreto-ley 12/2018, de 7 de septiembre, de seguridad de las redes y sistemas de información.
3. https://www.boe.es/diario_boe/txt.php?id=BOE-A-2021-1192 RD 43/2021 por el que se desarrolla el Real Decreto-ley 12/2018, de 7 de septiembre, de seguridad de las redes y sistemas de información.
4. https://www.boe.es/diario_boe/txt.php?id=BOE-A-2022-7191 Esquema Nacional de Seguridad, Real Decreto 311/2022, de 3 de mayo.
5. https://administracionelectronica.gob.es/pae_Home/pae_Documentacion/pae_Metodolog/pae_Magerit.html Metodología de Análisis de riesgos MAGERIT versión 3.
6. <https://www.ccn-cert.cni.es/documentos-publicos/1789-magerit-libro-i-metodo/file.html> Metodología de Análisis de riesgos MAGERIT versión 3 incorporada y resumida en el portal del CCN-CERT.
7. <https://www.iso.org/standard/73906.html> Norma ISO/IEC 27005:2018.
8. <https://pilar.ccn-cert.cni.es/> Portal CCN-CERT, herramienta PILAR.
9. https://www.pilar-tools.com/doc/manual_rm_es_20211.pdf Manual actualizado de la herramienta PILAR año 2021.
10. Manual oficial de la herramienta PILAR (versión 7)

10.2 BIBLIOGRAFÍA PARA AMPLIAR EL TEMA

11. <https://www.incibe.es/protege-tu-empresa/blog/ceo-ciso-cio-roles-ciberseguridad> INCIBE, roles en ciberseguridad
12. NIST for Cybersecurity Framework: <https://www.nist.gov/cyberframework>
13. INCIBE, colección “Protege tu empresa”, Análisis de Riesgos sencillo en cinco pasos: <https://www.incibe.es/protege-tu-empresa/blog/analisis-riesgos-pasos-sencillo>
14. https://store.isaca.org/s/store?cid=pr_2002761&Appeal=pr#/store/browse/detail/a2S4w000004KoYtEAK Implementing the NIST Cybersecurity Framework Using COBIT 2019 | Digital | English ISACA, colección de libros digitales.
15. <https://rac.es/ficheros/doc/01204.pdf> David Ríos Insúa: Matemáticas para un mundo más seguro: Del análisis de riesgos al análisis de riesgos adversarios
16. <https://www.enisa.europa.eu/topics/threat-risk-management/risk-management/current-risk/risk-management-inventory> Inventario de ENISA de herramientas y metodologías para Análisis de Riesgos.
17. https://www.redseguridad.com/especialidades-tic/gestion-y-gobierno-ti/seguridad-integral-la-evolucion-necesaria_20210628.html Artículo sobre seguridad integral.
18. https://administracionelectronica.gob.es/pae_Home/pae_Actualidad/pae_Noticias/Anio2022/Mayo/Noticia-2022-05-26-Union-Europea-refuerza-ciberseguridad-directiva-NIS-2.html Noticia sobre la próxima aprobación de esta modificación de la directiva anterior.

19. <https://www.globalsuitesolutions.com/wp-content/uploads/2020/11/GRC-plus.pdf> Herramienta Global Suite GRC
20. <https://www.ccn-cert.cni.es/series-ccn-stic/800-guia-esquema-nacional-de-seguridad/542-ccn-stic-824-informaci%C3%B3n-del-estado-de-seguridad/file.html> Guía CCN-STIC-824 para elaborar el informe INES
21. <https://www.ealde.es/mapa-calor-matriz-riesgos-mapa-riesgos/> Mapa de calor para el análisis de riesgos.